

Problem Statement

During the initial phase of our registration flow, we encountered a pattern of abuse targeting our SMS-based phone number verification system. Specifically, the registration API was being repeatedly triggered using randomly generated mobile numbers. Since the system initially allowed SMS messages to be sent to any unregistered number without sufficient safeguards, it became an easy target for malicious actors.

The following security gaps were identified:

- No restriction on how many SMS messages could be sent to a single phone number.
- SMS body content had no validation or limitations.
- There were no country-level restrictions for recipients.
- IP-based throttling was not in place.
- Requests from VPNs or anonymized sources were not filtered.
- No bot or automation protection was applied initially.

As a result, attackers were able to flood the registration endpoint with random numbers, consuming SMS resources at scale.

To mitigate this abuse, we implemented a multi-layered protection strategy:

1. Hidden Google reCAPTCHA with Score-Based Validation: Introduced as the first line of defense to detect and block automated or low-trust traffic before any processing.
2. Rate Limiting per Phone Number: Limited to one SMS per number per minute to prevent rapid repeated requests.
3. IP-Based Throttling: Restricted each IP to a maximum of five requests per minute.
4. Country Whitelisting: Allowed SMS to be sent only to approved countries based on business needs.
5. SMS Body Restrictions: Enforced character count rules to ensure valid and efficient messaging.
6. VPN and Proxy Blocking: Blocked SMS delivery to connections originating from VPNs or proxies.
7. Platform- and Country-Based Rate Limits: Applied different thresholds per platform (web, Android) and per country, tuned based on historical usage patterns and peak marketing periods.

Despite initial improvements, the abuse evolved — such as rotating IPs and bypassing basic protections — which required strengthening our logic further. These comprehensive controls now form the foundation of our OTP flood protection system and help ensure secure, fair, and resource-efficient SMS delivery.